Acesso de funcionários e gerentes

Proposta de autenticação, papéis e proteção do dashboard

IDEIA CENTRAL · O aplicativo pode mostrar telas diferentes por perfil; o servidor é quem decide se a pessoa tem permissão.

Como está hoje

A tela coleta nome, loja e turno para a experiência do demonstrativo. O perfil é salvo localmente e o sincronizador Firebase usa autenticação anônima. Nas regras atuais do Firestore, qualquer usuário autenticado pode ler os agregados usados pelo dashboard. Isso permite testar a sincronização, mas ainda não comprova a identidade nem separa funcionário de gerente.

Para o demonstrativo

FUNCIONÁRIO	GERENTE
Manter a entrada simples com nome, loja e turno. Deixar minigames e progresso disponíveis no HUB.	Exibir uma entrada de gerência separada. Para mostrar apenas o fluxo, pode haver um código demonstrativo claramente tratado como simulação.

Para uma versão real

1. Contas de gerente são criadas ou aprovadas por um administrador. O acesso pode usar e-mail e senha ou o provedor adotado pela organização. Não é necessário abrir um cadastro público de gerentes.

2. Um serviço confiável atribui o papel de gerente e, se necessário, a loja autorizada. O app usa esse papel para montar a interface; as regras do Firestore também verificam o papel e o escopo da loja antes de liberar os dados.

3. Funcionários só precisam de conta permanente se o produto realmente precisar reconhecer a mesma pessoa entre aparelhos ou sessões. Se continuarem anônimos, o app não deve tratar nome digitado como identidade verificada.

Convites e códigos

Não colocar um código de gerente fixo dentro do app: o código pode ser extraído ou a verificação contornada. Um convite real deve ser validado no servidor, expirar, ser de uso único e ter tentativas limitadas. Uma Cloud Function pode validar o pedido; App Check ajuda a reduzir chamadas vindas de apps não legítimos, mas não substitui autenticação ou regras.

Armazenamento e segurança

Guardar dados de perfil no Firestore associados ao UID da conta, com acesso limitado pelas regras. Guardar credenciais no Firebase Authentication; nunca salvar senhas no Firestore. O Firestore criptografa os dados em repouso e usa TLS em trânsito por padrão. As regras de acesso continuam sendo necessárias para limitar quem pode ler ou alterar cada dado.

Fluxo recomendado

Uma separação simples para evoluir sem redesenhar o app inteiro

01 ENTRADA	02 AUTORIZAÇÃO	03 EXPERIÊNCIA
Funcionário entra pelo fluxo simples atual. Gerente entra com conta aprovada ou convite.	Firebase Authentication identifica a conta. Um serviço confiável atribui papel e loja permitida.	O HUB mostra recursos do perfil. As regras do Firestore protegem os dados mesmo se a interface for alterada.

Decisões práticas

• **Agora:** se o objetivo for só apresentar o conceito, mostrar um botão “Acesso da gerência” e uma tela de demonstração; não usar o código visual como proteção de dados.

• **Quando o dashboard tiver dados reais:** autenticar gerentes com conta aprovada e restringir as leituras nas regras do Firestore por papel e loja.

• **Antes de guardar dados pessoais:** definir quais informações são necessárias, quem pode consultá-las e por quanto tempo devem ser mantidas.

Fontes oficiais do Firebase

Custom claims e controle de acesso · Regras de segurança

Autenticação anônima no Unity · Cloud Functions callable

Criptografia no Firestore · App Check no Unity